

title: "Trabajo Final Integrador — Auditoría de Cumplimiento PCI-DSS v4.0.1" subtitle: "Empresa auditada: CardProcess S.A." author: - "Holgado Adrián — Líder de Auditoría" - "Guzmán Mauro Emir — Auditor Senior" - "Chumba Fernando Javier — Especialista Técnico" - "Gil Fadda Angel — Auditor" - "Sosa Leandro Martín — Auditor" date: "Junio 2026" lang: es toc: true toc-depth: 2 numbersections: true geometry: margin=2.5cm mainfont: "Calibri" fontsize: 11pt

Portada y datos del encargo

Campo	Detalle
Título del trabajo	Auditoría de Cumplimiento PCI-DSS v4.0.1 — Diagnóstico de Seguridad para Expansión Comercial
Empresa auditada	CardProcess S.A.
Domicilio	Av. Corrientes 1234, Piso 8, Ciudad Autónoma de Buenos Aires, Argentina
Actividad	Plataforma fintech de billetera digital y procesamiento de pagos B2B
Tipo de entidad	Startup Fintech — Proveedor de Servicios de Pago (PSP) en proceso de certificación PCI-DSS Nivel 1
Etapas de la empresa	Scale-up (fundada 2023); negociaciones activas con clientes bancarios y corporativos
Volumen transaccional	~120.000 transacciones/mes (proyección: 400.000/mes en 2027)
Dotación	23 empleados
Marco de referencia	PCI-DSS v4.0.1 (Payment Card Industry Data Security Standard)
Normativa complementaria	Ley 25.326 (Protección de Datos Personales — Argentina); BCRA Comunicación "A" 7724; ISO/IEC 27002:2022
Firma auditora	Holgado, Guzmán & Asociados — Auditores en Sistemas de Información
Equipo auditor	Holgado Adrián (Líder); Guzmán Mauro Emir (Senior); Chumba Fernando Javier (Especialista Técnico); Gil Fadda Angel (Auditor); Sosa Leandro Martín (Auditor)
Período auditado	28/04/2026 al 20/06/2026 (8 semanas)
Fecha del informe	22 de junio de 2026
Confidencialidad	Documento clasificado — distribución restringida a Directorio y Gerencia de TI

Glosario de Objetos de Control (OC)

A los efectos de este TFI se definen tres **Objetos de Control (OC)** que estructuran todo el trabajo:

OC	Denominación	Requisitos PCI-DSS asociados
OC-1	Gestión de identidades, accesos y trazabilidad	Req. 7 (Restricción de acceso), Req. 8 (Identificación/autenticación), Req. 10 (Registro y monitoreo)
OC-2	Seguridad de red, configuración y endurecimiento	Req. 1 (Controles de seguridad de red), Req. 2 (Configuraciones seguras)
OC-3	Gestión de personal, terceros y aspectos formales	Req. 12 (Políticas/programa de seguridad — alcance parcial), ISO 27002:2022 Control 6.6 (acuerdos de confidencialidad)

Nota sobre nomenclatura COSO: Las preguntas del CEAC (Entregable 2) se clasifican por componente del marco COSO 2013 (Ambiente de Control, Evaluación de Riesgos, Actividades de Control), de modo de articular el enfoque de control interno con el marco técnico PCI-DSS.

ENTREGABLE 1 — Propuesta de Auditoría

1.0 Presentación de la firma auditora

Razón social: Holgado, Guzmán & Asociados — Auditores en Sistemas de Información

Constitución y trayectoria: La firma fue fundada en 2019 en la Ciudad Autónoma de Buenos Aires por profesionales egresados de la Universidad Tecnológica Nacional, con especialización en auditoría de cumplimiento normativo en sistemas de información, seguridad de la información y privacidad de datos para el sector financiero y de medios de pago. Desde su fundación ha ejecutado más de 25 encargos de auditoría y consultoría en organizaciones del sector, con especial experiencia en diagnósticos de postura de seguridad para empresas tecnológicas en etapas de crecimiento.

Áreas de especialización:

- Auditorías de cumplimiento PCI-DSS (v3.2.1 y v4.0.1) para procesadoras, emisores, adquirentes y startups fintech.
- Diagnósticos de brecha y preparación para certificación PCI-DSS en empresas de alto crecimiento.
- Evaluaciones de cumplimiento bajo normativa BCRA (Com. A 7724, Com. A 6375, Com. A 7017).
- Auditorías de brecha y certificación ISO/IEC 27001 / 27002.
- Revisiones de arquitectura de seguridad en entornos CDE y pruebas de configuración segura.
- Gestión de riesgos de TI y evaluación de terceros proveedores.

Trabajos previos relevantes (ficticios):

Año	Cliente (ficticio)	Encargo
2022	PayGroup S.A.	Diagnóstico de brecha PCI-DSS v3.2.1 y plan de remediación para startup de pagos en etapa de certificación.
2023	Banco Regional del Noroeste	Auditoría de cumplimiento BCRA Com. A 6375 — ciberseguridad.
2024	QuickPay S.R.L.	Evaluación de postura de seguridad y riesgo tecnológico en plataforma fintech de pagos móviles pre-lanzamiento.
2025	FinTrust S.A.	Revisión de controles de acceso y gestión de identidades (ISO 27001) como requisito previo a proceso de due diligence con inversor.

Dotación: 8 profesionales en planta; 5 asignados al presente encargo.

Matrículas y afiliaciones: Los profesionales actuantes se encuentran matriculados ante el Consejo Profesional de Ciencias Informáticas de la Provincia de Córdoba (CPCI) y son miembros de ISACA Capítulo Buenos Aires.

1.1 Código de ética profesional

La firma Holgado, Guzmán & Asociados se rige por los siguientes principios éticos en la totalidad de sus actuaciones profesionales:

N°	Principio	Descripción
1	Independencia	Los auditores no mantienen ni mantendrán relación laboral, societaria, económica ni personal con CardProcess S.A. que pueda comprometer la objetividad del encargo. Cualquier conflicto de interés potencial deberá ser declarado antes del inicio del trabajo.
2	Objetividad	Los hallazgos, conclusiones y recomendaciones se basarán exclusivamente en evidencia verificable, reproducible y documentada, sin influencias externas de ninguna naturaleza.
3	Confidencialidad	Toda la información obtenida durante el encargo —incluyendo datos de tarjetahabientes, configuraciones, logs y documentación interna— es estrictamente confidencial y no será divulgada a terceros sin autorización escrita del Cliente, salvo requerimiento legal expreso.
4	Competencia profesional	Los auditores poseen la formación académica, la experiencia práctica y las certificaciones necesarias para ejecutar el encargo. Se comprometen a la formación continua y a no aceptar tareas que superen su nivel de competencia verificable.
5	Integridad	Los auditores actuarán con honestidad, franqueza y veracidad en todas sus comunicaciones, informando los hallazgos desfavorables con la misma transparencia que los resultados positivos.
6	Diligencia profesional	El trabajo se desarrollará con el cuidado, la rigurosidad y la planificación propias de un auditor competente, documentando adecuadamente cada prueba realizada y cada evidencia obtenida.
7	Responsabilidad	Los profesionales asumen responsabilidad personal por la calidad de su trabajo, el cumplimiento de los plazos acordados y la correcta custodia de la información del Cliente.
8	Cumplimiento normativo	La actuación se encuadra en las normas de ISACA (ITAF), el PCI SSC, el CPCI y las disposiciones del ordenamiento legal argentino vigente, en particular la Ley 25.326 y las comunicaciones del BCRA.

1.2 Comprensión del negocio del cliente

1.2.1 Contexto estratégico — por qué esta auditoría

CardProcess S.A. es una startup fintech fundada en 2023 que ha desarrollado una plataforma propietaria de billetera digital y procesamiento de pagos B2B. Al cierre del primer cuatrimestre de 2026, la empresa procesa aproximadamente 120.000 transacciones mensuales con proyección de alcanzar 400.000 en 2027.

La empresa se encuentra en una **etapa de scale-up**: ha validado su producto con tres clientes piloto y mantiene negociaciones activas con dos bancos de tamaño mediano y una red de fintech B2B para contratos de mayor escala. En este proceso comercial surgió una exigencia concreta de sus prospectos:

Los clientes bancarios y corporativos exigen, como condición previa a la firma del contrato, evidencia documentada de que CardProcess S.A. cumple con los requisitos de seguridad del estándar PCI-DSS v4.0.1.

Esta exigencia responde a una lógica de responsabilidad distribuida: cuando una entidad bancaria contrata a un procesador de pagos, asume responsabilidad ante las marcas de tarjetas (Visa, Mastercard) y ante el BCRA si

ese procesador sufre un incidente que exponga datos de tarjetahabientes. Un informe de auditoría independiente transfiere parte de esa carga probatoria al proveedor auditado y reduce el riesgo percibido del comprador.

El encargo responde simultáneamente a dos necesidades estratégicas de CardProcess S.A.:

1. **Diagnóstico objetivo de postura de seguridad.** La empresa nunca fue auditada externamente. El equipo de tecnología —reducido y de perfil startup— requiere una evaluación independiente que identifique brechas reales antes de que las descubran sus clientes o, peor, un atacante. El diagnóstico permitirá priorizar inversiones de seguridad con criterio y evidencia.
2. **Habilitador comercial y de negocio.** El informe de auditoría será utilizado como documento de debida diligencia (*due diligence*) en los procesos de venta B2B con clientes bancarios y corporativos. Contar con una auditoría independiente diferencia a CardProcess S.A. de competidores sin validación externa y acelera el cierre de contratos al reducir fricciones en las evaluaciones de riesgo de los compradores.

¿Por qué PCI-DSS v4.0.1 específicamente?

El estándar PCI-DSS v4.0.1 es el marco técnico exigido contractualmente por Visa y Mastercard para toda entidad que procese, almacene o transmita datos de tarjetahabientes. Dado que el producto central de CardProcess S.A. involucra procesamiento de datos de PAN y autenticación de pagos, este estándar es no negociable para operar en el ecosistema de pagos formal. La elección de los Requisitos 1, 2, 7, 8 y 10 como foco de la presente auditoría responde al análisis preliminar de riesgo realizado por la firma auditora: estos cinco requisitos cubren los vectores de compromiso más frecuentes en startups fintech (credenciales débiles o por defecto, ausencia de MFA, exposición de red y logs insuficientes para respuesta a incidentes).

La presente auditoría no emite una certificación PCI-DSS formal (esto requiere la intervención de un Qualified Security Assessor —QSA— reconocido por el PCI SSC). Su propósito es producir un **diagnóstico técnico independiente** que CardProcess S.A. pueda presentar a sus prospectos como evidencia de madurez en seguridad y utilizarlo como hoja de ruta para alcanzar la certificación formal en 2027.

1.2.2 Descripción de la organización

CardProcess S.A. es una startup fintech fundada en 2023 con domicilio en Av. Corrientes 1234, Piso 8, CABA, Argentina. Ha desarrollado una plataforma propietaria de billetera digital y procesamiento de pagos B2B que permite a sus clientes emitir tarjetas virtuales, procesar pagos y gestionar flujos de dinero digital. Al volumen actual (~120.000 transacciones/mes), la empresa se aproxima al umbral que la clasificaría como **Service Provider de Nivel 1** ante las redes Visa/Mastercard (>300.000 transacciones anuales), lo que hace urgente la preparación para la certificación. Cuenta con 23 empleados distribuidos en las áreas de Producto & Tecnología, Operaciones, Seguridad de la Información y Administración.

1.2.3 Sector y modelo de negocio

Característica	Descripción
Industria	Fintech — billetera digital y medios de pago B2B
Etapas	Scale-up; producto validado con 3 clientes piloto; negociaciones activas con bancos y corporaciones
Clientes actuales	3 clientes piloto (empresas medianas de comercio electrónico)
Clientes objetivo	Bancos medianos, fintech B2B, empresas con necesidad de pagos corporativos
Modelo de ingresos	SaaS mensual (acceso a plataforma) + comisión por transacción procesada
Regulador principal	BCRA (Com. A 7724 — lineamientos de ciberseguridad para entidades del sistema financiero)
Estándar de cumplimiento requerido	PCI-DSS v4.0.1 (exigido por Visa/Mastercard y por prospectos bancarios como condición contractual)
Marco legal de protección de datos	Ley 25.326 — Protección de Datos Personales (Argentina)
Consecuencia del incumplimiento	Imposibilidad de cerrar contratos con clientes bancarios; eventual multa de redes (USD 5.000–100.000/mes); pérdida de reputación en etapa crítica de crecimiento

1.2.4 Procesos de TI clave

1. **Autorización de transacciones:** recepción del PAN desde el banco emisor vía TLS 1.2, validación contra DB-SRV-01 y respuesta en tiempo real (< 2 segundos). Es el proceso central del negocio y el de mayor exposición.
2. **Emisión de tarjetas virtuales:** generación y gestión de PAN virtuales para clientes B2B, con almacenamiento cifrado en DB-SRV-01.
3. **Administración del CDE:** gestión de servidores APP-SRV-01/02/03 y DB-SRV-01 incluyendo parchado, control de accesos, gestión de cuentas y monitoreo.
4. **Accesos remotos:** administración de VPN (VPN-GW-01) para acceso del equipo técnico y de proveedores externos al CDE desde entornos de trabajo remoto (práctica habitual en startups).
5. **Monitoreo y logging:** registro de eventos de seguridad en servidor de logs (VLAN 300) con alertas configuradas sobre anomalías.
6. **Gestión de proveedores:** soporte de infraestructura tercerizado a Mantenimiento S.R.L., con acceso al CDE para tareas de mantenimiento.

1.2.5 Riesgos inherentes de la industria

#	Riesgo	Descripción	Req. PCI-DSS
R-1	Exfiltración de datos de tarjeta (PAN)	Compromiso de DB-SRV-01 podría exponer PANs de tarjetahabientes, generando responsabilidad civil y regulatoria. En una startup, este evento puede ser terminal para el negocio.	Req. 3, 4, 10
R-2	Acceso no autorizado al CDE	Credenciales débiles o por defecto, ausencia de MFA o acceso remoto no controlado son vectores críticos en entornos de trabajo remoto típicos de startups.	Req. 7, 8
R-3	Ataques de red (MITM, sniffing)	Comunicaciones no cifradas o protocolos inseguros dentro del CDE facilitan la captura de credenciales o datos en tránsito.	Req. 1, 2, 4
R-4	Deuda técnica de seguridad	Las startups frecuentemente priorizan velocidad de desarrollo sobre seguridad; configuraciones por defecto, cuentas genéricas y políticas de contraseñas débiles son hallazgos típicos.	Req. 2, 8
R-5	Riesgo de terceros y proveedores	Acceso de proveedores sin controles formales es un vector de amenaza de baja visibilidad y alta probabilidad, especialmente cuando los contratos no contemplan cláusulas de confidencialidad.	Req. 12.8
R-6	Retención insuficiente de evidencia forense	Sin logs históricos suficientes, los incidentes no pueden investigarse retroactivamente, impidiendo la respuesta ante fraude y dificultando el cumplimiento de exigencias probatorias del BCRA.	Req. 10

1.3 Objetivos del encargo

Objetivo general: Evaluar el grado de cumplimiento de CardProcess S.A. respecto de los Requisitos 1, 2, 7, 8 y 10 del estándar PCI-DSS v4.0.1 sobre el Entorno de Datos de Tarjetahabientes (CDE — *Cardholder Data Environment*), emitiendo un informe de hallazgos, brechas y recomendaciones de remediación que sirva como herramienta de diagnóstico interno y como evidencia de postura de seguridad ante clientes bancarios y corporativos.

Objetivos específicos:

1. Verificar la existencia y eficacia de controles de seguridad de red sobre el CDE (Req. 1).
2. Comprobar el endurecimiento ("hardening") y la eliminación de configuraciones y credenciales por defecto en los componentes del CDE (Req. 2).
3. Evaluar la restricción de acceso a datos de tarjetahabientes según el principio de necesidad de saber (Req. 7).
4. Validar los mecanismos de identificación y autenticación de usuarios, incluyendo MFA y políticas de contraseñas (Req. 8).
5. Verificar el registro, la protección y la retención de los logs de actividad del CDE (Req. 10).
6. Evaluar el tratamiento formal del personal interno y de terceros con acceso al CDE (Req. 12 parcial, ISO 27002:2022).

7. Determinar el nivel de confianza del ambiente de control, identificar las brechas de mayor prioridad y emitir una hoja de ruta de remediación orientada a la obtención de la certificación PCI-DSS formal.

1.4 Alcance — Delimitación del CDE

El alcance se circunscribe al **Cardholder Data Environment (CDE)** de CardProcess S.A. y a los sistemas conectados o que impactan en su seguridad. Quedan **dentro del alcance**:

Componente	Identificador	Plataforma	Zona / VLAN
Servidor de procesamiento 1	APP-SRV-01	Linux RHEL 8	CDE — VLAN 100
Servidor de procesamiento 2	APP-SRV-02	Linux RHEL 8	CDE — VLAN 100
Servidor de procesamiento 3	APP-SRV-03	Linux RHEL 8	CDE — VLAN 100
Base de datos de tarjetas	DB-SRV-01	SQL Server 2019	CDE restringida — VLAN 100
Terminal de operación 1-4	POS-TRM-01 a 04	Windows 10	Operativa — VLAN 200
Firewall perimetral CDE	FW-CDE-01	Fortinet FortiGate 100F	Frontera CDE
Switch de acceso CDE	SW-CDE-01	Cisco Catalyst 2960	CDE — VLAN 100
Gateway VPN accesos remotos	VPN-GW-01	(appliance perimetral)	Frontera externa

Fuera del alcance: sistemas de RRHH, contabilidad, correo corporativo y otros activos no conectados al CDE ni con capacidad de impactar su seguridad. La validez de la segmentación que excluye estos activos se prueba como parte del trabajo (PT-05).

Limitaciones declaradas: la auditoría se basa en evidencia recolectada durante el período 28/04/2026–20/06/2026 mediante muestreo; no constituye una Evaluación QSA formal ni emite un Reporte de Cumplimiento (RoC) oficial ante el PCI SSC.

1.5 Metodología

El trabajo aplica una metodología mixta basada en cuatro técnicas de auditoría:

Técnica	Descripción	Aplicación
Entrevistas	Reuniones estructuradas con responsables de TI, Seguridad, RRHH y el equipo fundador.	CEO/CTO, Gerente de TI, Administrador de Red, Responsable de Seguridad, Jefe de RRHH.
Revisión documental	Análisis de políticas, diagramas de red, matrices de acceso, legajos, NDAs y tickets de cambio.	Políticas de seguridad, diagrama CDE, matriz de accesos, contratos de terceros.
Pruebas técnicas	Inspección de configuraciones, reglas de firewall, listados de usuarios, escaneo de puertos, análisis de logs.	FW-CDE-01, SW-CDE-01, APP/DB-SRV, VPN-GW-01.
Observación directa	Verificación presencial de prácticas y controles físicos/lógicos.	Sesiones de login, accesos de terceros, prácticas operativas del equipo.

El enfoque es de **riesgo**: se prioriza la evaluación de los controles cuya falla tendría mayor impacto sobre la confidencialidad de los datos de tarjetahabientes (PAN, datos sensibles de autenticación) y sobre la viabilidad comercial de la empresa.

Marco normativo de referencia: PCI-DSS v4.0.1 (marco principal); ISO/IEC 27002:2022 (controles complementarios en OC-3); Ley 25.326 (marco legal argentino); BCRA Com. A 7724 (lineamientos sectoriales).

Enfoque de auditoría: cumplimiento normativo (compliance-based) con elementos de prueba sustantiva en OC-1 (análisis de logs) y OC-2 (pruebas técnicas de configuración).

1.6 Equipo asignado con roles y responsabilidades

Rol	Nombre	Responsabilidades	Horas asignadas
Líder de Auditoría	Holgado Adrián	Dirección estratégica del encargo; relación con el Directorio y CEO de CardProcess; revisión de calidad de papeles de trabajo; firma del informe final; coordinación de reuniones de apertura, seguimiento y cierre.	44 h
Auditor Senior	Guzmán Mauro Emir	Ejecución de pruebas técnicas OC-1 y OC-2; revisión de reglas de firewall, matriz de accesos y configuraciones de servidores; redacción de hallazgos críticos; supervisión técnica del equipo.	128 h
Especialista Técnico	Chumba Fernando Javier	Pruebas técnicas especializadas: escaneo de puertos (nmap), análisis detallado de logs de acceso, verificación de credenciales por defecto, análisis de configuraciones de red y VPN.	100 h
Auditor	Gil Fadda Angel	Revisión documental: políticas de seguridad, diagrama CDE, matriz de accesos, contratos de terceros; evaluación OC-3 (aspectos formales y NDAs); elaboración de papeles de trabajo documentales.	96 h
Auditor	Sosa Leandro Martín	Análisis de logs y retención; revisión de legajos de personal y acuerdos de confidencialidad; armado y numeración de papeles de trabajo; soporte en reuniones de entrevistas.	96 h

Total: 464 horas-profesional distribuidas en 8 semanas de trabajo.

1.7 Cronograma estimado — 8 semanas

Semana	Período	Actividades principales	Técnica principal	Responsables
Sem. 1	28/04 – 02/05/2026	Reunión de apertura con CEO, CTO y Gerente de TI · Relevamiento general del CDE · Recolección de documentación (políticas, diagrama de red, contratos) · Primeras entrevistas y comprensión del entorno tecnológico	Entrevistas / Revisión documental	Holgado (coord.) + todo el equipo
Sem. 2	05/05 – 09/05/2026	Revisión diagrama CDE y segmentación VLAN · Análisis reglas FW-CDE-01 (deny-all, reglas explícitas) · Inicio verificación de credenciales por defecto en dispositivos · Verificación del diagrama de flujo de datos de tarjetahabientes	Pruebas técnicas / Revisión documental	Guzmán M.E. / Chumba F.J.
Sem. 3	12/05 – 16/05/2026	Escaneo de puertos y servicios abiertos (PT-08) · Pruebas de autenticación con credenciales por defecto en DB-SRV-01 y APP-SRV-02 (PT-07) · Inicio revisión de matriz de accesos al CDE (PT-01)	Pruebas técnicas	Chumba F.J. / Guzmán M.E.
Sem. 4	19/05 – 23/05/2026	Verificación de cuentas individuales vs. cuentas compartidas (PT-02) · Prueba MFA en VPN-GW-01 (PT-03) · Revisión de política de contraseñas en servidores CDE (PT-04)	Pruebas técnicas / Entrevistas	Guzmán M.E. / Chumba F.J.
Sem. 5	26/05 – 30/05/2026	Recolección y análisis de logs de acceso al CDE — últimos 30 días (PT-12) · Identificación de anomalías · Revisión de legajos de personal (PT-09) y NDAs internos (PT-10)	Análisis de logs / Revisión documental	Sosa L.M. / Gil Fadda A.
Sem. 6	02/06 – 06/06/2026	Verificación de NDAs de proveedores externos — Mantenimiento S.R.L. (PT-11) · Reunión intermedia de hallazgos preliminares con CTO · Cierre del trabajo de campo · Verificación de controles adecuados	Entrevistas / Revisión documental	Gil Fadda A. / Sosa L.M. / Holgado (coord.)
Sem. 7	09/06 – 13/06/2026	Consolidación de los 12 PT + PT-OBS · Redacción de observaciones en formato NCCCE (5-8 obs.) · Documentación de controles adecuados (3-5) · Revisión de calidad por Líder	Análisis / Redacción	Holgado / Guzmán M.E. / equipo
Sem. 8	16/06 – 20/06/2026	Redacción Parte A — Resumen Ejecutivo para Alta Dirección · Redacción Parte B — Informe Detallado con Hoja de Ruta PCI-DSS · Reunión de cierre con Directorio y CEO · Entrega del informe final	Redacción / Entrevistas	Holgado / Guzmán M.E.

Nota académica: La defensa oral ante el docente está programada para el 25 de junio de 2026 conforme al cronograma institucional de UTN-FRT.

1.8 Presupuesto de honorarios

Los honorarios se calculan conforme a las tarifas recomendadas por el **Consejo Profesional de Ciencias Informáticas de la Provincia de Córdoba (CPCI)**, actualizadas al **índice IPIM de mayo de 2026**, expresadas en pesos argentinos (ARS). Los valores se facturarán en ARS a los precios vigentes al momento de cada hito de pago.

Nota sobre variabilidad cambiaria: Dado el contexto macroeconómico argentino, los honorarios expresados en ARS son válidos por **30 días corridos** desde la fecha de la propuesta. Ante una variación del índice IPIM superior al **10%** en el período de ejecución, las partes acordarán el reajuste proporcional de los honorarios pendientes.

1.8.1 Referencia tarifaria CPCI — roles aplicados

Rol auditor	Categoría CPCI equivalente	Tarifa CPCI (\$ hora x demanda)
Líder de Auditoría	Conducción y Liderazgo — Líder Director de Proyecto	\$120.858,75
Auditor Senior	Consultoría — Consultor Seguridad de la Información	\$113.839,02
Especialista Técnico	IT Infraestructura Tecnológica — Seguridad Informática	\$94.610,47
Auditor (×2)	Analistas Funcionales — Auditor Interno Informático	\$72.958,58

Fuente: CPCI — Honorarios Recomendados, actualización 05-2026 (índice IPIM). Consulta: junio 2026.

1.8.2 Detalle por profesional — horas y honorarios

Rol	Profesional	Tarifa (\$/h)	Horas asignadas	Subtotal (ARS)
Líder de Auditoría	Holgado Adrián	\$120.858,75	44 h	\$5.317.785,00
Auditor Senior	Guzmán Mauro Emir	\$113.839,02	128 h	\$14.571.394,56
Especialista Técnico	Chumba Fernando Javier	\$94.610,47	100 h	\$9.461.047,00
Auditor	Gil Fadda Angel	\$72.958,58	96 h	\$7.004.023,68
Auditor	Sosa Leandro Martín	\$72.958,58	96 h	\$7.004.023,68
SUBTOTAL honorarios profesionales			464 h	\$43.358.273,92

1.8.3 Resumen presupuestario

Concepto	Importe (ARS)
Honorarios profesionales	\$43.358.273,92
Gastos administrativos y materiales (5%)	\$2.167.913,70
Subtotal neto	\$45.526.187,62
IVA (21%)	\$9.560.499,40
TOTAL DEL ENCARGO	\$55.086.687,02

Condiciones de pago: 40% al inicio del encargo (firma de la carta de compromiso) — \$22.034.674,81 ARS · 60% contra entrega del informe final aprobado — \$33.052.012,21 ARS.

Validez de la propuesta: 30 días corridos desde la fecha de emisión. Los valores se ajustarán por índice IPIM conforme a lo indicado al inicio de esta sección.

1.9 Carta de compromiso

Buenos Aires, 14 de abril de 2026

CARTA DE COMPROMISO DE AUDITORÍA

Señores **CardProcess S.A.** Av. Corrientes 1234, Piso 8 — Ciudad Autónoma de Buenos Aires **Att.: Lic. Valentina Torres — CEO & Co-Fundadora**

Por medio de la presente, **Holgado, Guzmán & Asociados — Auditores en Sistemas de Información** (en adelante, "la Firma") y **CardProcess S.A.** (en adelante, "el Cliente") formalizan los términos y condiciones del encargo de auditoría que se detalla a continuación:

1. Objeto del encargo

La Firma realizará una auditoría de cumplimiento del estándar **PCI-DSS v4.0.1** sobre el Cardholder Data Environment (CDE) de CardProcess S.A., con foco en los Requisitos 1, 2, 7, 8 y 10, durante el período **28/04/2026 al 20/06/2026** (8 semanas). El informe resultante tendrá por finalidad proveer al Cliente un diagnóstico técnico independiente de su postura de seguridad y una hoja de ruta hacia la certificación formal.

2. Responsabilidades de la Firma auditora

- Ejecutar el encargo conforme a los estándares de ISACA (ITAF), el PCI SSC y el Código de Ética enunciado en el apartado 1.1 del presente documento.
- Mantener estricta confidencialidad sobre toda la información del Cliente durante y después del encargo.
- Comunicar de manera inmediata a la Gerencia de TI cualquier hallazgo de riesgo crítico que se detecte durante el trabajo de campo, sin esperar a la emisión del informe final.
- Emitir el informe final dentro de los 5 días hábiles posteriores a la finalización del trabajo de campo (fecha estimada de entrega: 22/06/2026).
- Realizar una reunión intermedia de hallazgos preliminares al finalizar la Semana 6, de modo de anticipar las observaciones críticas y permitir al Cliente iniciar acciones de remediación sin demora.

3. Responsabilidades del Cliente

- Proveer acceso irrestricto a los sistemas, documentación y personal del CDE durante el período de auditoría.
- Designar un interlocutor técnico (Gerente de TI o CTO) para la coordinación operativa del encargo.
- No interferir en los juicios profesionales ni en las conclusiones del equipo auditor.
- Notificar de inmediato cualquier incidente de seguridad ocurrido durante el período auditado que pueda afectar la integridad de la evidencia.

4. Alcance y limitaciones

La presente auditoría cubre los Requisitos 1, 2, 7, 8 y 10 de PCI-DSS v4.0.1 sobre el CDE definido en el apartado 1.4. No constituye una Evaluación QSA formal ni emite un Reporte de Cumplimiento (RoC) oficial ante el PCI SSC. El informe es de uso interno y para procesos de due diligence comercial del Cliente.

5. Honorarios y condiciones de pago

Las partes acuerdan los honorarios detallados en el apartado 1.8 (\$55.086.687,02 ARS + IVA incluido), con el esquema de pago 40/60 allí establecido. Los valores están sujetos a ajuste por índice IPIM conforme a las condiciones indicadas en dicho apartado.

6. Vigencia

El presente compromiso tiene vigencia desde la firma de ambas partes hasta la entrega del informe final, con posibilidad de extensión por acuerdo escrito entre las partes.

POR LA FIRMA AUDITORA	POR CARDPROCESS S.A.
Firma: _____	Firma: _____
Holgado Adrián	Lic. Valentina Torres
Líder de Auditoría	CEO & Co-Fundadora
Holgado, Guzmán & Asociados	CardProcess S.A.
Buenos Aires, 14 de abril de 2026	Buenos Aires, 14 de abril de 2026

Bibliografía y Referencias — Entregable 1

Normas y estándares

- PCI Security Standards Council. (2022). *Payment Card Industry Data Security Standard (PCI-DSS) v4.0.1*. PCI SSC. Recuperado de https://www.pcisecuritystandards.org/document_library/
- International Organization for Standardization. (2022). *ISO/IEC 27002:2022 — Information security, cybersecurity and privacy protection: Information security controls*. ISO.
- ISACA. (2014). *Information Technology Assurance Framework (ITAF)*, 3.ª edición. ISACA. Recuperado de <https://www.isaca.org/resources/isaca-journal/issues/2014/volume-6/information-technology-assurance-framework-itaf-3rd-edition>

Marco legal argentino

- Honorable Congreso de la Nación Argentina. (2000). *Ley N.º 25.326 — Protección de Datos Personales*. InfoLeg. Recuperado de <https://servicios.infoleg.gob.ar/infolegInternet/anexos/60000-64999/64790/texact.htm>
- Banco Central de la República Argentina. (2023). *Comunicación "A" 7724 — Lineamientos de Seguridad de la Información y Ciberseguridad para entidades financieras*. BCRA. Recuperado de <https://www.bcra.gob.ar/Pdfs/comytexord/A7724.pdf>

Recursos profesionales y fuentes consultadas

- Colegio Profesional de Ciencias Informáticas de la Provincia de Córdoba (CPCI). (2026, mayo). *Honorarios Recomendados — Actualizados por índice IPIM*. Recuperado de <https://cpcipc.org.ar/honorarios-recomendados/>
- ISACA Capítulo Buenos Aires. *Recursos y certificaciones para auditores de sistemas*. Recuperado de <https://engage.isaca.org/buenosaireschapter/home>
- PCI Security Standards Council. *Document Library — PCI DSS v4.0.1 resources*. Recuperado de https://www.pcisecuritystandards.org/document_library/

ENTREGABLE 2 — CEAC y Nivel de Confianza

2.1 Cuestionario de Evaluación del Ambiente de Control (CEAC)

El CEAC evalúa el ambiente de control mediante 15 preguntas distribuidas entre los tres OC, clasificadas por componente COSO 2013. La escala de respuesta es **Sí = puntaje pleno**, **Parcial = 50%**, **No = 0**. La **ponderación** (1 a 3) refleja la criticidad de cada control. El **puntaje obtenido** = Ponderación × factor de respuesta (Sí=1; Parcial=0,5; No=0).

N°	Componente COSO	Pregunta de control	Resp.	Pond. (1-3)	Puntaje obt.	Observación
1	Ambiente de Control	¿Existe una política de seguridad de la información formalmente aprobada y vigente?	Sí	3	3,0	Política v4 aprobada 03/2026.
2	Ambiente de Control	¿Todo el personal interno con acceso al CDE tiene NDA firmado y vigente?	Sí	3	3,0	Verificado en PT-10. Control adecuado CA-04.
3	Ambiente de Control	¿Los proveedores externos con acceso al CDE poseen NDA/cláusula de confidencialidad firmada?	No	3	0,0	Mantenimiento S.R.L. sin NDA → OBS-07.
4	Ambiente de Control	¿Existe un responsable formal de seguridad de la información designado?	Sí	2	2,0	Rol asignado al Gte. de TI.
5	Ambiente de Control	¿Los legajos del personal con acceso al CDE están completos y actualizados?	Parcial	2	1,0	Faltan registros de capacitación PCI. PT-09.
6	Evaluación de Riesgos	¿Se realiza un análisis de riesgos periódico sobre el CDE?	Parcial	3	1,5	Último análisis 2024, desactualizado.
7	Evaluación de Riesgos	¿Existe un proceso formal de gestión de cambios con tickets para el CDE?	Parcial	3	1,5	Cambio en FW-CDE-01 sin ticket → anomalía A-05.
8	Evaluación de Riesgos	¿Se identifican y eliminan las configuraciones y credenciales por defecto?	No	3	0,0	sa/sa y admin/admin activos → OBS-01/02.
9	Evaluación de Riesgos	¿Se evalúa el riesgo de accesos remotos al CDE (MFA)?	No	3	0,0	VPN sin MFA → OBS-04.
10	Actividades de Control	¿El firewall aplica política "deny-all" por defecto?	Sí	3	3,0	Verificado PT-06. Control adecuado CA-01.
11	Actividades de Control	¿La red está segmentada (CDE aislado de otras zonas)?	Sí	3	3,0	VLAN 100/200/300. CA-02. PT-05.
12	Actividades de Control	¿Cada usuario del CDE tiene una cuenta individual (sin cuentas compartidas)?	No	3	0,0	Cuenta "operador_cde" compartida → OBS-03.
13	Actividades de Control	¿La política de contraseñas cumple Req. 8.3 (≥12 car., complejidad, expiración)?	Parcial	2	1,0	Cumple en APP-SRV-01/03; no uniforme. CA-03.

Nº	Componente COSO	Pregunta de control	Resp.	Pond. (1-3)	Puntaje obt.	Observación
14	Actividades de Control	¿Los logs de acceso se retienen al menos 12 meses (Req. 10.7)?	No	3	0,0	Retención de 90 días → OBS-05.
15	Actividades de Control	¿Se han deshabilitado servicios/puertos inseguros (p. ej., Telnet)?	No	2	0,0	Telnet (23) activo en SW-CDE-01 → OBS-06.

2.2 Cálculo del Nivel de Confianza

Puntaje máximo posible = suma de ponderaciones = 3+3+3+2+2+3+3+3+3+3+3+2+3+2 = **41 puntos**.

Puntaje obtenido = 3,0+3,0+0,0+2,0+1,0+1,5+1,5+0,0+0,0+3,0+3,0+0,0+1,0+0,0+0,0 = **19,0 puntos**.

Fórmula del Nivel de Confianza:

$$NC = \frac{\text{Puntaje obtenido}}{\text{Puntaje máximo posible}} \times 100 = \frac{19,0}{41} \times 100 = 46,34\%$$

Riesgo de control (complementario): $RC = 100\% - NC = 53,66\%$.

Escala de interpretación:

Nivel de Confianza	Rango	Riesgo de Control	Resultado
Bajo	0% – 50%	Alto	← RESULTADO (46,34%)
Moderado	51% – 75%	Medio	
Alto	76% – 100%	Bajo	

Conclusión del CEAC: El ambiente de control de CardProcess S.A. presenta un **Nivel de Confianza BAJO (46,34%)** y, en consecuencia, un **Riesgo de Control ALTO (53,66%)**. Si bien existen controles de red sólidos (firewall deny-all, segmentación, NDAs internos), las deficiencias en gestión de credenciales por defecto, MFA, cuentas compartidas y retención de logs deterioran significativamente la confianza. Esto justifica una estrategia de auditoría **sustantiva ampliada** y una remediación priorizada.

ENTREGABLE 3 — Diagrama del CDE y Flujo de Datos

3.1 Descripción textual de la arquitectura

El CDE de CardProcess S.A. se estructura en tres zonas lógicas separadas por VLAN y mediadas por el firewall FW-CDE-01 (Fortinet FortiGate 100F), que controla todo el tráfico inter-zona bajo política "deny-all".

Capa / Zona	VLAN	Componentes	Función	Rango de red
Frontera externa	—	VPN-GW-01, FW-CDE-01 (interfaz WAN)	Punto único de ingreso remoto y filtrado perimetral.	IP pública / 200.x
Zona CDE	VLAN 100	APP-SRV-01/02/03, SW-CDE-01	Procesamiento de transacciones.	10.10.10.0/24
Zona CDE restringida	VLAN 100 (sub-segmento)	DB-SRV-01	Almacenamiento cifrado del PAN. Acceso solo desde APP-SRV.	10.10.10.50/32
Zona Operativa	VLAN 200	POS-TRM-01 a 04	Operación y monitoreo por personal interno.	192.168.20.0/24
Zona Administración	VLAN 300	Estaciones de administración de red/sistemas	Gestión de FW, switch y servidores.	172.16.30.0/24

3.2 Tabla de flujos de datos de tarjetahabientes

#	Origen	Destino	Protocolo	Puerto	Tipo de dato	Cifrado	Observación
F1	Banco emisor (externo)	FW-CDE-01 → APP-SRV-01	HTTPS / TLS 1.2	443	PAN + datos de transacción	Sí (TLS)	Ingreso autorizado por regla explícita.
F2	APP-SRV-01/02/03	DB-SRV-01	TDS sobre TLS	1433	PAN (almacenado cifrado)	Sí	Acceso restringido a VLAN 100.
F3	DB-SRV-01	APP-SRV (respuesta)	TDS sobre TLS	1433	PAN truncado / token	Sí	Solo respuesta a consulta autorizada.
F4	POS-TRM (VLAN 200)	APP-SRV-03	HTTPS / TLS 1.2	443	PAN enmascarado en pantalla	Sí	Operadores ven solo últimos 4 dígitos.
F5	VPN-GW-01 (remoto)	APP-SRV-02 (administración)	SSH	22	Configuración (sin CHD)	Sí	Sin MFA → OBS-04.
F6	APP-SRV / DB-SRV	Servidor de logs (VLAN 300)	Syslog/TLS	6514	Eventos de seguridad	Sí	Retención solo 90 días → OBS-05.
F7 (anómalo)	DB-SRV-01	IP externa 185.220.101.45	HTTPS/SFTP	443/22	Archivo .csv (45 MB, posible PAN)	—	Exfiltración sospechada → anomalía A-06.

Nota sobre CVV/datos sensibles de autenticación: Conforme Req. 3.2, los datos sensibles de autenticación (CVV/CVV2, PIN, banda magnética completa) **no deben almacenarse tras la autorización**. Se verificó que DB-SRV-01 no almacena CVV; únicamente el PAN cifrado. El CVV transita en F1 (autorización) y se descarta.

3.3 Zonas de seguridad y controles en cada frontera

Frontera	Control implementado	Estado
Externa → CDE (FW-CDE-01)	Política deny-all + reglas explícitas; inspección stateful.	Adecuado (CA-01).
CDE ↔ Operativa (VLAN 100/200)	Segmentación VLAN; ACL en SW-CDE-01.	Adecuado (CA-02), salvo Telnet abierto (OBS-06).
CDE ↔ Administración (VLAN 300)	Tráfico de gestión segregado; SSH.	Parcial — falta MFA en acceso remoto.
CDE restringida (DB-SRV-01)	Acceso solo desde APP-SRV; cifrado en reposo.	Comprometido por credencial sa/sa (OBS-01).

3.4 Leyenda de componentes

Sigla	Significado
CDE	Cardholder Data Environment (Entorno de Datos de Tarjetahabientes)
PAN	Primary Account Number (Número de cuenta principal de la tarjeta)
CHD	Cardholder Data (Datos de tarjetahabiente)
CVV	Card Verification Value (dato sensible de autenticación)
MFA	Multi-Factor Authentication (Autenticación multifactor)
VLAN	Virtual Local Area Network (Red de área local virtual)
TDS	Tabular Data Stream (protocolo de SQL Server)
FW	Firewall

ENTREGABLE 4 — Registro de Logs con Anomalías

4.1 Registro de accesos al CDE (muestra de 30 entradas, mayo 2026)

Fecha/Hora	Usuario	IP Origen	Dispositivo Destino	Acción	Resultado	Anomalía
02/05 08:14	mquirolga	172.16.30.12	APP-SRV-01	Login SSH	Éxito	No
02/05 09:02	jperez	192.168.20.21	APP-SRV-03	Login app	Éxito	No
03/05 10:31	fbianchi	172.16.30.15	FW-CDE-01	Consulta reglas	Éxito	No
04/05 11:45	jperez	192.168.20.21	APP-SRV-03	Consulta tx	Éxito	No
05/05 03:47	admin	185.143.223.7	APP-SRV-02	Login SSH	Éxito	Sí (A-02)
05/05 08:10	operador_cde	192.168.20.22	APP-SRV-03	Login app	Éxito	Sí (A-03)
06/05 09:20	operador_cde	192.168.20.23	APP-SRV-03	Login app	Éxito	Sí (A-03)
06/05 14:05	sa	10.10.10.30	DB-SRV-01	Login SQL	Éxito	Sí (A-01)
07/05 22:11	desconocido	185.220.101.45	VPN-GW-01	Login VPN	Éxito	Sí (A-04)
08/05 02:33	(n/a)	203.0.113.88	APP-SRV-01	Login SSH	Fallo	Sí (A-03b)
08/05 02:33	(n/a)	203.0.113.88	APP-SRV-01	Login SSH	Fallo	Sí (A-03b)
08/05 02:34	root	203.0.113.88	APP-SRV-01	Login SSH	Fallo	Sí (A-03b)
08/05 02:34	root	203.0.113.88	APP-SRV-01	Login SSH	Fallo	Sí (A-03b)
08/05 02:35	admin	203.0.113.88	APP-SRV-01	Login SSH	Fallo	Sí (A-03b)
08/05 02:35	admin	203.0.113.88	APP-SRV-01	Login SSH	Fallo (×12 total)	Sí (A-05 fuerza bruta)
09/05 09:00	mquirolga	172.16.30.12	APP-SRV-01	Login SSH	Éxito	No

Fecha/Hora	Usuario	IP Origen	Dispositivo Destino	Acción	Resultado	Anomalía
10/05 16:42	tecnico_ext1	172.16.30.40	APP-SRV-02	Login SSH	Éxito	Sí (A-07 sin NDA)
11/05 11:15	jperez	192.168.20.21	APP-SRV-03	Consulta tx	Éxito	No
12/05 13:50	fbianchi	172.16.30.15	SW-CDE-01	Login Telnet (23)	Éxito	Sí (A-08 Telnet)
13/05 10:05	ldominguez	172.16.30.18	DB-SRV-01	Consulta SQL	Éxito	No
14/05 17:20	sa	10.10.10.31	DB-SRV-01	Export datos	Éxito	Sí (A-06)
14/05 17:22	sa	10.10.10.31	DB-SRV-01	Transfer .csv 45MB → 185.220.101.45	Éxito	Sí (A-06 exfiltración)
15/05 08:30	jperez	192.168.20.21	APP-SRV-03	Login app	Éxito	No
16/05 04:18	admin	200.45.12.9	FW-CDE-01	Cambio config (regla NAT)	Éxito	Sí (A-09 sin ticket)
17/05 09:45	mquirolga	172.16.30.12	APP-SRV-01	Login SSH	Éxito	No
18/05 10:30	operador_cde	192.168.20.24	APP-SRV-03	Login app	Éxito	Sí (A-03)
19/05 12:00	tecnico_ext2	172.16.30.41	APP-SRV-02	Login SSH	Éxito	Sí (A-07 sin NDA)
20/05 15:10	jperez	192.168.20.21	APP-SRV-03	Consulta tx	Éxito	No
21/05 08:05	ldominguez	172.16.30.18	DB-SRV-01	Consulta SQL	Éxito	No
22/05 23:55	sa	91.219.236.18	DB-SRV-01	Login SQL	Fallo	Sí (A-01b)

4.2 Análisis de anomalías detectadas

ID	Descripción	Requisito PCI-DSS afectado	Riesgo (A/M/B)	Acción recomendada
A-01	Login exitoso a DB-SRV-01 con usuario por defecto "sa" (credencial sa/sa).	Req. 2.1 / Req. 8.2.1	Alto	Deshabilitar/renombrar "sa", asignar contraseña robusta única, usar cuentas nominales.
A-02	Acceso a APP-SRV-02 a las 03:47 AM desde IP externa con usuario "admin".	Req. 2.1 / Req. 8.6	Alto	Investigar acceso, restringir login a horario/origen, eliminar cuenta por defecto.
A-03	Uso de cuenta compartida "operador_cde" por múltiples IP/usuarios.	Req. 8.2.1	Alto	Crear cuentas individuales por operador; eliminar cuenta genérica.
A-03b/A-05	12 intentos fallidos consecutivos en APP-SRV-01 (fuerza bruta).	Req. 8.3.4 (bloqueo) / Req. 10.6	Alto	Configurar bloqueo tras 6 intentos; alertar al SOC; revisar fail2ban.
A-04	Acceso VPN exitoso desde 185.220.101.45 (nodo de salida Tor) no registrado.	Req. 1.3 / Req. 8.4.2 (MFA)	Crítico	Implementar MFA, geo-bloqueo, lista blanca de orígenes VPN.
A-06	Exportación y transferencia de .csv de 45 MB desde DB-SRV-01 a IP externa.	Req. 10.6 / Req. 1.3.2 (egress)	Crítico	Bloquear egress no autorizado, DLP, investigar posible fuga de PAN.
A-07	Accesos de tecnico_ext1/ext2 (proveedor) al CDE sin NDA firmado.	Req. 12.8.3	Alto	Suspender accesos hasta NDA firmado; registrar y supervisar.
A-08	Login por Telnet (puerto 23, texto plano) a SW-CDE-01.	Req. 2.2.1 / Req. 2.2.5	Medio	Deshabilitar Telnet; usar exclusivamente SSH.
A-09	Cambio de configuración (regla NAT) en FW-CDE-01 sin ticket de cambio.	Req. 1.2.1 / Req. 6.5.1 (gestión de cambios)	Medio	Exigir ticket previo; revisar regla creada; control de cambios.

ENTREGABLE 5 — Plan y Programa de Auditoría por OC

5.1 OC-1 — Gestión de identidades, accesos y trazabilidad

Plan de auditoría — OC-1

OC	Objetivo	Riesgo identificado	Criterio de evaluación (PCI-DSS)
OC-1	Verificar restricción de acceso, identificación única, autenticación robusta y trazabilidad.	Accesos no controlados al CHD; cuentas compartidas; falta de MFA; logs insuficientes.	Req. 7.2, 8.2.1, 8.3, 8.4.2, 10.7

Programa de auditoría — OC-1

N°	Descripción de la prueba	Técnica	Responsable	Fecha plan.	Ref. PT
P-1.1	Revisar matriz de accesos al CDE y necesidad de saber.	Rev. documental	Bianchi	06/05	PT-01
P-1.2	Verificar que cada usuario tenga cuenta individual.	Prueba técnica	Bianchi	06/05	PT-02
P-1.3	Verificar MFA en accesos remotos VPN.	Prueba técnica	Bianchi	06/05	PT-03
P-1.4	Revisar política de contraseñas en servidores CDE.	Prueba técnica	Domínguez	06/05	PT-04
P-1.5	Revisar configuración de retención de logs.	Prueba técnica	Domínguez	07/05	PT-12

5.2 OC-2 — Seguridad de red, configuración y endurecimiento

Plan de auditoría — OC-2

OC	Objetivo	Riesgo identificado	Criterio de evaluación (PCI-DSS)
OC-2	Verificar controles de red, segmentación, reglas de firewall y eliminación de configuraciones/credenciales por defecto.	Exposición del CDE; credenciales por defecto; puertos inseguros.	Req. 1.2.1, 1.3, 2.1, 2.2.1

Programa de auditoría — OC-2

N°	Descripción de la prueba	Técnica	Responsable	Fecha plan.	Ref. PT
P-2.1	Revisar diagrama de red y segmentación del CDE.	Rev. documental	Bianchi	05/05	PT-05
P-2.2	Revisar reglas del firewall FW-CDE-01 (deny-all).	Prueba técnica	Bianchi	05/05	PT-06
P-2.3	Verificar credenciales por defecto en dispositivos CDE.	Prueba técnica	Bianchi	05/05	PT-07
P-2.4	Escanear puertos y servicios abiertos.	Prueba técnica	Domínguez	05/05	PT-08

5.3 OC-3 — Gestión de personal, terceros y aspectos formales**Plan de auditoría — OC-3**

OC	Objetivo	Riesgo identificado	Criterio de evaluación
OC-3	Verificar tratamiento formal de personal interno y terceros con acceso al CDE.	Personal/terceros sin acuerdos de confidencialidad; legajos incompletos.	Req. 12.1, 12.8.3; ISO 27002:2022 Control 6.6

Programa de auditoría — OC-3

N°	Descripción de la prueba	Técnica	Responsable	Fecha plan.	Ref. PT
P-3.1	Revisar legajos del personal con acceso CDE.	Rev. documental	Domínguez	07/05	PT-09
P-3.2	Verificar NDAs del personal interno.	Rev. documental	Domínguez	07/05	PT-10
P-3.3	Verificar NDAs de proveedores externos.	Rev. documental / Entrevista	Domínguez	07/05	PT-11

ENTREGABLE 6 — Papeles de Trabajo

PT-01: Revisión de matriz de accesos al CDE

Campo	Detalle
Referencia	PT-01
OC	OC-1
Objetivo	Verificar que los accesos al CDE estén asignados según necesidad de saber y por rol.
Requisito PCI-DSS	Req. 7.2 (Restricción de acceso basada en necesidad de saber y función laboral)
Procedimiento aplicado	Solicitud y análisis de la matriz de accesos (RBAC); cruce con organigrama y funciones.
Evidencia obtenida	Matriz "Accesos_CDE_2026.xlsx" con 14 usuarios. Roles: 3 administradores (mquiroga, fbianchi, sysadmin), 8 operadores, 3 cuentas técnicas. Hallazgo: la cuenta "operador_cde" figura asignada a 3 personas (J. Pérez, M. Sosa, R. Gómez); existe regla "deny-all" base correcta en FW. La matriz no registra fecha de última revisión de privilegios.
Resultado	No Conforme (parcial: existe matriz, pero con cuenta compartida y sin revisión periódica).
Observación	PT-OBS → OBS-03
Auditor	Cr. Federico Bianchi
Fecha	06/05/2026

PT-02: Verificación de cuentas individuales

Campo	Detalle
Referencia	PT-02
OC	OC-1
Objetivo	Confirmar que cada usuario posea identificador único, sin cuentas compartidas.
Requisito PCI-DSS	Req. 8.2.1 (Asignación de ID único a cada usuario antes de otorgar acceso)
Procedimiento aplicado	Listado de cuentas locales y de aplicación en APP-SRV-01/02/03; entrevista a operadores.
Evidencia obtenida	Extracto <code>/etc/passwd</code> (APP-SRV-03): <code>operador_cde:x:1502:1502:Operador CDE compartido:/home/operador_cde:/bin/bash</code> . Entrevista: "Los tres operadores del turno usan la misma cuenta <code>operador_cde</code> porque es más práctico" (J. Pérez, operador). Logs confirman uso desde IP 192.168.20.22, .23 y .24.
Resultado	No Conforme
Observación	PT-OBS → OBS-03
Auditor	Cr. Federico Bianchi
Fecha	06/05/2026

PT-03: Verificación de MFA en accesos remotos

Campo	Detalle
Referencia	PT-03
OC	OC-1
Objetivo	Verificar que los accesos remotos al CDE utilicen autenticación multifactor.
Requisito PCI-DSS	Req. 8.4.2 (MFA para todo acceso al CDE) y 8.5.1
Procedimiento aplicado	Inspección de configuración de VPN-GW-01; prueba de conexión remota controlada.
Evidencia obtenida	Configuración VPN-GW-01: <code>auth-method = local-password; mfa = disabled</code> . Prueba de login remoto exitosa solo con usuario/contraseña, sin segundo factor. Log A-04 muestra acceso VPN desde 185.220.101.45 sin MFA. Entrevista al Administrador de Red: "El MFA está en el roadmap pero aún no se implementó".
Resultado	No Conforme
Observación	PT-OBS → OBS-04
Auditor	Cr. Federico Bianchi
Fecha	06/05/2026

PT-04: Revisión de política de contraseñas

Campo	Detalle
Referencia	PT-04
OC	OC-1
Objetivo	Verificar que la política de contraseñas cumpla los parámetros mínimos.
Requisito PCI-DSS	Req. 8.3.6 (mínimo 12 caracteres, alfanumérica) y 8.3.9 (rotación)
Procedimiento aplicado	Inspección de <code>/etc/security/pwquality.conf</code> y <code>chage</code> ; revisión de GPO/políticas.
Evidencia obtenida	APP-SRV-01 y APP-SRV-03: <code>minlen=12; minclass=3; maxdays=90</code> . Conforme . APP-SRV-02: <code>minlen=8; maxdays=0</code> (sin expiración) — más débil. DB-SRV-01: política SQL con "Enforce password policy" deshabilitado para "sa".
Resultado	Conforme en APP-SRV-01/03 (sustenta CA-03); No Conforme en APP-SRV-02 y DB-SRV-01.
Observación	PT-OBS → OBS-01, OBS-02 (relacionado)
Auditor	Sr. Lucas Domínguez
Fecha	06/05/2026

PT-05: Revisión del diagrama de red del CDE

Campo	Detalle
Referencia	PT-05
OC	OC-2
Objetivo	Verificar la existencia y exactitud del diagrama de red y la segmentación del CDE.
Requisito PCI-DSS	Req. 1.2.1 (diagrama de red actualizado que identifique conexiones del CDE)
Procedimiento aplicado	Revisión del diagrama "Topologia_CDE_v3.vsd" (fecha 02/2026); cotejo con configuración real de VLAN en SW-CDE-01.
Evidencia obtenida	Diagrama presente y fechado 02/2026. VLAN 100 (CDE), 200 (operativa), 300 (administración) coinciden con <code>show vlan brief</code> del switch. El diagrama identifica flujos de CHD. Refleja correctamente FW-CDE-01 como frontera.
Resultado	Conforme
Observación	— (sustenta CA-02)
Auditor	Cr. Federico Bianchi
Fecha	05/05/2026

PT-06: Revisión de reglas del firewall FW-CDE-01

Campo	Detalle
Referencia	PT-06
OC	OC-2
Objetivo	Verificar que el firewall aplique política restrictiva por defecto con reglas explícitas.
Requisito PCI-DSS	Req. 1.3 (restricción de tráfico hacia/desde el CDE) y 1.3.2 (deny por defecto)
Procedimiento aplicado	Exportación del rule-set de FW-CDE-01; análisis de regla implícita final.
Evidencia obtenida	Política implícita final: Deny ALL (log habilitado). Reglas explícitas: (1) Allow 443 from BancoEmisor to APP-SRV-01 ;(2) Allow 1433 from APP-SRV-* to DB-SRV-01 ; (3) Allow 22 from VLAN300 to APP-SRV-* . Hallazgo secundario: existe regla NAT agregada el 16/05 (log A-09) sin ticket de cambio asociado.
Resultado	Conforme respecto del deny-all (sustenta CA-01); observación de gestión de cambios en regla NAT.
Observación	— (CA-01); nota a OBS de control de cambios
Auditor	Cr. Federico Bianchi
Fecha	05/05/2026

PT-07: Verificación de credenciales por defecto en dispositivos CDE

Campo	Detalle
Referencia	PT-07
OC	OC-2
Objetivo	Verificar la eliminación/cambio de credenciales y cuentas por defecto del proveedor.
Requisito PCI-DSS	Req. 2.1 (cambiar defaults del proveedor antes de instalar en la red)
Procedimiento aplicado	Pruebas de autenticación controladas con credenciales por defecto; revisión de cuentas.
Evidencia obtenida	DB-SRV-01 (SQL Server 2019): login exitoso con <code>sa / sa</code> (autenticado, confirmado por log A-01). APP-SRV-02 (RHEL 8): login exitoso con <code>admin / admin</code> . APP-SRV-01 y APP-SRV-03: credenciales por defecto eliminadas (conforme). FW-CDE-01 y SW-CDE-01: cuenta admin con contraseña personalizada.
Resultado	No Conforme (DB-SRV-01 y APP-SRV-02).
Observación	PT-OBS → OBS-01, OBS-02
Auditor	Cr. Federico Bianchi
Fecha	05/05/2026

PT-08: Revisión de puertos y servicios abiertos

Campo	Detalle
Referencia	PT-08
OC	OC-2
Objetivo	Identificar puertos/servicios innecesarios o inseguros en componentes del CDE.
Requisito PCI-DSS	Req. 2.2.1 / 2.2.5 (solo servicios necesarios; deshabilitar inseguros)
Procedimiento aplicado	Escaneo de puertos (nmap controlado) sobre SW-CDE-01 y servidores; revisión de servicios.
Evidencia obtenida	<code>nmap SW-CDE-01 : 23/tcp open telnet , 22/tcp open ssh .</code> Telnet (texto plano) habilitado junto a SSH. Log A-08 confirma login Telnet. Servidores APP/DB: solo puertos esperados (22, 443, 1433).
Resultado	No Conforme (SW-CDE-01 con Telnet activo).
Observación	PT-OBS → OBS-06
Auditor	Sr. Lucas Domínguez
Fecha	05/05/2026

PT-09: Revisión de legajos de personal con acceso CDE

Campo	Detalle
Referencia	PT-09
OC	OC-3
Objetivo	Verificar que los legajos del personal con acceso al CDE estén completos.
Requisito PCI-DSS	Req. 12.1 (política de seguridad) y 12.6 (concientización)
Procedimiento aplicado	Muestreo de 8 legajos de personal con acceso al CDE; revisión de contenido.
Evidencia obtenida	8/8 legajos contienen contrato y descripción de puesto. 6/8 carecen de constancia de capacitación PCI-DSS del último año (Req. 12.6.3). Todos poseen NDA (ver PT-10).
Resultado	No Conforme parcial (falta evidencia de capacitación).
Observación	Nota de gestión (concientización)
Auditor	Sr. Lucas Domínguez
Fecha	07/05/2026

PT-10: Verificación de NDAs del personal interno

Campo	Detalle
Referencia	PT-10
OC	OC-3
Objetivo	Verificar que todo el personal interno con acceso al CDE tenga NDA firmado y vigente.
Requisito PCI-DSS / ISO	ISO/IEC 27002:2022 Control 6.6 (Acuerdos de confidencialidad); Req. 12.8 (relación)
Procedimiento aplicado	Cotejo de listado de 11 empleados con acceso al CDE contra NDAs archivados en RRHH.
Evidencia obtenida	11/11 empleados internos poseen NDA firmado y vigente (firmas entre 2024 y 2026, cláusula de confidencialidad sobre CHD). Constancias en legajo digital.
Resultado	Conforme
Observación	— (sustenta CA-04)
Auditor	Sr. Lucas Domínguez
Fecha	07/05/2026

PT-11: Verificación de NDAs de proveedores externos

Campo	Detalle
Referencia	PT-11
OC	OC-3
Objetivo	Verificar que los proveedores con acceso al CDE tengan acuerdos de confidencialidad.
Requisito PCI-DSS	Req. 12.8.3 (proceso de compromiso con proveedores con acceso al CHD) y 12.8.2
Procedimiento aplicado	Revisión del contrato con Mantenimiento S.R.L.; entrevista a RRHH y a Compras.
Evidencia obtenida	Contrato de servicios de mantenimiento vigente, sin cláusula de confidencialidad/NDA específica sobre datos de tarjetahabientes . Los técnicos tecnico_ext1 y tecnico_ext2 acceden al CDE (logs A-07) sin NDA firmado. RRHH: "El NDA con el proveedor nunca se gestionó".
Resultado	No Conforme
Observación	PT-OBS → OBS-07
Auditor	Sr. Lucas Domínguez
Fecha	07/05/2026

PT-12: Revisión de retención de logs

Campo	Detalle
Referencia	PT-12
OC	OC-1
Objetivo	Verificar que los logs de actividad del CDE se retengan el período mínimo exigido.
Requisito PCI-DSS	Req. 10.7 (retención de al menos 12 meses, 3 disponibles inmediatamente)
Procedimiento aplicado	Revisión de la política de retención y de la configuración del servidor de logs (VLAN 300).
Evidencia obtenida	Configuración del servidor syslog: <code>retention = 90 days; rotate + purge</code> . Logs anteriores a 90 días eliminados automáticamente. Política documentada indica "90 días" como objetivo. Confirmado: no existe respaldo histórico de 12 meses.
Resultado	No Conforme
Observación	PT-OBS → OBS-05
Auditor	Sr. Lucas Domínguez
Fecha	07/05/2026

PT-OBS — Índice de Papeles de Observación

PT-OBS	Hallazgo asociado	Origen PT	Severidad
PT-OBS-01	Credencial por defecto sa/sa en DB-SRV-01	PT-07	Crítico
PT-OBS-02	Credencial por defecto admin/admin en APP-SRV-02	PT-07	Crítico
PT-OBS-03	Cuenta compartida "operador_cde"	PT-01, PT-02	Alto
PT-OBS-04	Ausencia de MFA en VPN	PT-03	Alto
PT-OBS-05	Retención de logs de 90 días	PT-12	Alto
PT-OBS-06	Telnet activo en SW-CDE-01	PT-08	Medio
PT-OBS-07	Técnicos de proveedor sin NDA	PT-11	Alto

ENTREGABLE 7 — Observaciones NCCCE

Estructura NCCCE: Número, Condición, Criterio, Causa, Efecto (consecuencia), más recomendación y responsable.

OBS-01: Credenciales por defecto en DB-SRV-01

Campo	Contenido
Número	OBS-01
OC	OC-2
Naturaleza	Deficiencia de control / Incumplimiento normativo
Condición	El usuario administrador "sa" de SQL Server 2019 en DB-SRV-01 mantiene la contraseña por defecto del proveedor (sa), con la cual se logró autenticación exitosa.
Criterio	Req. 2.1 — "Las cuentas, contraseñas y demás parámetros de seguridad por defecto del proveedor deben modificarse antes de instalar un sistema en la red."
Causa	Falta de procedimiento de hardening al desplegar la base de datos; ausencia de baseline de configuración segura verificado.
Consecuencia/Efecto	Acceso administrativo total a la base que contiene el PAN; riesgo de exfiltración masiva de datos de tarjetahabientes (relacionado con anomalía A-06). Compromiso directo del activo más crítico del CDE.
Evidencia	PT-07, PT-OBS-01; logs A-01 (login exitoso sa) y A-06.
Riesgo	Crítico
Recomendación	Cambiar de inmediato la contraseña de "sa" por una robusta y única; deshabilitar o renombrar la cuenta "sa"; habilitar "Enforce password policy"; usar cuentas nominales con privilegios mínimos.
Responsable sugerido	Administrador de Base de Datos / Gerente de TI
Plazo sugerido	Inmediato ($\leq$ 24-48 h)

OBS-02: Credenciales por defecto en APP-SRV-02

Campo	Contenido
Número	OBS-02
OC	OC-2
Naturaleza	Deficiencia de control / Incumplimiento normativo
Condición	El servidor APP-SRV-02 (RHEL 8) admite autenticación con la credencial por defecto <code>admin / admin</code> .
Criterio	Req. 2.1 — Eliminación/cambio de cuentas y contraseñas por defecto del proveedor.
Causa	Hardening incompleto en el alta del servidor; la política de contraseñas de APP-SRV-02 es más débil (minlen=8, sin expiración — PT-04).
Consecuencia/Efecto	Acceso administrativo no autorizado a un servidor de procesamiento; posible pivote hacia DB-SRV-01. Vinculado a anomalía A-02 (acceso 03:47 AM desde IP externa).
Evidencia	PT-07, PT-04, PT-OBS-02; log A-02.
Riesgo	Crítico
Recomendación	Eliminar/renombrar la cuenta "admin" por defecto; aplicar la misma política de contraseñas que APP-SRV-01/03; restringir login por origen y horario.
Responsable sugerido	Administrador de Sistemas / Gerente de TI
Plazo sugerido	Inmediato ($\leq 24-48$ h)

OBS-03: Cuenta compartida "operador_cde" en APP-SRV-03

Campo	Contenido
Número	OBS-03
OC	OC-1
Naturaleza	Deficiencia de control
Condición	Tres operadores (J. Pérez, M. Sosa, R. Gómez) comparten la cuenta genérica "operador_cde" en APP-SRV-03.
Criterio	Req. 8.2.1 — "Se asigna a todos los usuarios un ID único antes de otorgarles acceso a componentes del sistema o a datos de tarjetahabientes."
Causa	Práctica operativa de conveniencia; ausencia de control de provisión de cuentas individuales.
Consecuencia/Efecto	Pérdida de trazabilidad y no repudio: imposibilidad de atribuir acciones a un individuo, debilitando la investigación de incidentes.
Evidencia	PT-01, PT-02, PT-OBS-03; logs A-03 (uso desde múltiples IP).
Riesgo	Alto
Recomendación	Crear cuentas individuales para cada operador; eliminar la cuenta genérica; capacitar sobre prohibición de cuentas compartidas.
Responsable sugerido	Administrador de Sistemas
Plazo sugerido	30 días

OBS-04: MFA no implementado para acceso VPN remoto al CDE

Campo	Contenido
Número	OBS-04
OC	OC-1
Naturaleza	Deficiencia de control / Incumplimiento normativo
Condición	Los accesos remotos al CDE a través de VPN-GW-01 utilizan únicamente usuario y contraseña, sin segundo factor de autenticación.
Criterio	Req. 8.4.2 — "Se implementa MFA para todos los accesos al CDE."
Causa	MFA no desplegado (en roadmap); configuración VPN <code>mfa = disabled</code> .
Consecuencia/Efecto	Acceso remoto al CDE vulnerable a robo de credenciales y fuerza bruta; evidenciado por acceso desde nodo Tor (A-04).
Evidencia	PT-03, PT-OBS-04; logs A-04, A-05.
Riesgo	Alto
Recomendación	Implementar MFA (TOTP/hardware token) para todo acceso VPN al CDE; restringir orígenes y aplicar geo-bloqueo.
Responsable sugerido	Administrador de Red / Responsable de Seguridad
Plazo sugerido	30 días

OBS-05: Retención de logs insuficiente

Campo	Contenido
Número	OBS-05
OC	OC-1
Naturaleza	Incumplimiento normativo
Condición	Los logs de acceso al CDE se conservan solo 90 días; los registros anteriores se purgan automáticamente.
Criterio	Req. 10.7 — "El historial de auditoría se retiene por al menos 12 meses, con un mínimo de 3 meses disponibles inmediatamente para análisis."
Causa	Política de retención mal dimensionada (90 días); falta de almacenamiento de archivo histórico.
Consecuencia/Efecto	Imposibilidad de investigar incidentes ocurridos hace más de 90 días; incumplimiento directo de PCI-DSS y dificultad probatoria ante el BCRA.
Evidencia	PT-12, PT-OBS-05.
Riesgo	Alto
Recomendación	Ampliar la retención a ≥ 12 meses; implementar almacenamiento de archivo (cold storage) y verificar integridad (Req. 10.5).
Responsable sugerido	Responsable de Seguridad / Administrador de Sistemas
Plazo sugerido	60 días

OBS-06: Puerto Telnet (23) activo en SW-CDE-01

Campo	Contenido
Número	OBS-06
OC	OC-2
Naturaleza	Deficiencia de control
Condición	El switch SW-CDE-01 (Cisco Catalyst 2960) tiene habilitado el servicio Telnet (puerto 23) en texto plano, junto con SSH.
Criterio	Req. 2.2.1 / 2.2.5 — Configurar solo servicios necesarios y deshabilitar protocolos inseguros; el acceso administrativo no consola debe ser cifrado (Req. 2.2.7).
Causa	Configuración legada no endurecida; falta de revisión de servicios habilitados.
Consecuencia/Efecto	Credenciales de administración del switch transmitidas en texto plano, susceptibles de captura (sniffing) dentro del CDE.
Evidencia	PT-08, PT-OBS-06; log A-08 (login Telnet).
Riesgo	Medio
Recomendación	Deshabilitar Telnet (<code>no transport input telnet</code>); permitir solo SSH; aplicar ACL de gestión desde VLAN 300.
Responsable sugerido	Administrador de Red
Plazo sugerido	30 días

OBS-07: Técnicos de proveedor externo sin NDA con acceso al CDE

Campo	Contenido
Número	OBS-07
OC	OC-3
Naturaleza	Incumplimiento normativo
Condición	Dos técnicos de Mantenimiento S.R.L. (tecnico_ext1, tecnico_ext2) acceden al CDE sin acuerdo de confidencialidad (NDA) firmado.
Criterio	Req. 12.8.3 — "Existe un proceso establecido para contratar proveedores de servicios, incluyendo la debida diligencia." ISO/IEC 27002:2022 Control 6.6 — Acuerdos de confidencialidad.
Causa	NDA con el proveedor nunca gestionado; contrato sin cláusula de confidencialidad sobre CHD.
Consecuencia/Efecto	Exposición de datos de tarjetahabientes a terceros sin obligación contractual de confidencialidad; responsabilidad legal frente a la Ley 25.326.
Evidencia	PT-11, PT-OBS-07; logs A-07.
Riesgo	Alto
Recomendación	Suspender los accesos hasta firmar NDA; incorporar cláusula PCI/confidencialidad al contrato; mantener registro de proveedores con acceso al CHD (Req. 12.8.1).
Responsable sugerido	Gerente de TI / Asesoría Legal / RRHH
Plazo sugerido	Inmediato (acceso) / 30 días (formalización)

ENTREGABLE 8 — Controles Adecuados

CA-01: Política "deny-all" en FW-CDE-01

Campo	Detalle
Referencia	CA-01
OC	OC-2
Descripción del control	El firewall FW-CDE-01 (FortiGate 100F) aplica una política implícita de denegación total ("deny-all"), permitiendo únicamente el tráfico definido por reglas explícitas hacia/desde el CDE.
Requisito PCI-DSS	Req. 1.3.2 (restricción de tráfico; denegación por defecto)
Evidencia	PT-06: regla final <code>Deny ALL</code> con logging; reglas explícitas acotadas (443 banco, 1433 DB, 22 admin).
Conclusión	Control adecuado y eficaz. Reduce significativamente la superficie de exposición del CDE.

CA-02: Segmentación VLAN del CDE

Campo	Detalle
Referencia	CA-02
OC	OC-2
Descripción del control	La red está segmentada en VLAN 100 (CDE), 200 (operativa) y 300 (administración), aislando el CDE de las demás zonas.
Requisito PCI-DSS	Req. 1.4 (controles entre redes confiables y no confiables) y guía de segmentación.
Evidencia	PT-05: diagrama "Topologia_CDE_v3" coincide con <code>show vlan brief</code> de SW-CDE-01; ACL entre VLAN.
Conclusión	Control adecuado. La segmentación reduce el alcance del CDE; se recomienda probar su efectividad anualmente (Req. 11.4.5).

CA-03: Política de contraseñas compliant en APP-SRV-01 y APP-SRV-03

Campo	Detalle
Referencia	CA-03
OC	OC-1
Descripción del control	Las contraseñas locales en APP-SRV-01 y APP-SRV-03 cumplen Req. 8.3: mínimo 12 caracteres, complejidad (≥3 clases) y expiración a 90 días.
Requisito PCI-DSS	Req. 8.3.6 (longitud/complejidad) y 8.3.9 (rotación).
Evidencia	PT-04: <code>minlen=12; minclass=3; maxdays=90</code> en <code>pwquality.conf</code> y <code>login.defs</code> .
Conclusión	Control adecuado en estos dos servidores. Debe extenderse a APP-SRV-02 y DB-SRV-01 para uniformidad (ver OBS-02).

CA-04: NDAs firmados de todo el personal interno con acceso al CDE

Campo	Detalle
Referencia	CA-04
OC	OC-3
Descripción del control	La totalidad del personal interno (11 empleados) con acceso al CDE posee NDA firmado y vigente con cláusula de confidencialidad sobre datos de tarjetahabientes.
Requisito PCI-DSS / ISO	ISO/IEC 27002:2022 Control 6.6; alineado con Req. 12.8 (relación con terceros) y buenas prácticas de RRHH.
Evidencia	PT-10: 11/11 NDAs firmados (2024-2026) archivados en legajo digital de RRHH.
Conclusión	Control adecuado. Contrasta con la deficiencia de NDAs de terceros (OBS-07), que debe corregirse.

ENTREGABLE 9 — Parte A: Resumen Ejecutivo para Alta Dirección

Para: Directorio de CardProcess S.A. **De:** Holgado, Guzmán & Asociados — Auditores en Seguridad de la Información **Asunto:** Resultados de la Auditoría de Cumplimiento PCI-DSS v4.0.1 **Fecha:** 22 de junio de 2026

9.1 Síntesis del encargo y alcance

Se auditó el cumplimiento de CardProcess S.A. respecto del estándar internacional PCI-DSS v4.0.1 (requisitos 1, 2, 7, 8 y 10) sobre el entorno donde se procesan y almacenan los datos de las tarjetas (CDE). El trabajo abarcó servidores de procesamiento, la base de datos de tarjetas, el firewall, el switch del CDE y los accesos remotos, durante mayo de 2026.

9.2 Hallazgos principales (en lenguaje no técnico)

- Dos sistemas críticos —entre ellos la base de datos donde residen los números de tarjeta— **conservan las claves de fábrica del proveedor** ("admin/admin" y "sa/sa"), lo que equivale a dejar la caja fuerte con la combinación que viene impresa en el manual.
- **El acceso remoto a los sistemas no exige doble verificación** (solo usuario y contraseña). Se detectó un ingreso desde una conexión anonimizada en el exterior.
- **Los registros de actividad se borran a los 90 días**, cuando la norma exige conservarlos un año. Esto impide investigar incidentes pasados.
- **Tres operadores comparten una misma cuenta**, por lo que no es posible saber quién hizo qué.
- **Dos técnicos de un proveedor externo acceden a los datos de tarjetas sin haber firmado un acuerdo de confidencialidad.**
- En el lado positivo: el firewall y la separación de redes están **bien configurados**, y todo el personal propio tiene su acuerdo de confidencialidad firmado.

9.3 Nivel de cumplimiento general

Indicador	Resultado
Nivel de Confianza del ambiente de control (CEAC)	46,34% — BAJO
Semáforo general	 ROJO (no apto para certificación en el estado actual)
Observaciones críticas	2
Observaciones altas	4
Observaciones medias	1
Controles adecuados destacados	4

9.4 Top 3 riesgos críticos

1. **Base de datos de tarjetas con clave de fábrica (OBS-01):** un atacante podría extraer todos los números de tarjeta. Riesgo de fuga masiva.
2. **Acceso remoto sin doble verificación (OBS-04):** puerta de entrada al corazón del sistema con una sola barrera fácil de vulnerar.
3. **Servidor de procesamiento con clave de fábrica (OBS-02):** segundo punto de compromiso administrativo total.

9.5 Mensaje clave: impacto en el negocio

El estado actual expone a CardProcess S.A. a:

- **Pérdida de la certificación PCI-DSS**, condición para operar con los bancos emisores y las marcas de tarjetas.
- **Multas de las marcas** (Visa/Mastercard) que pueden ir de **USD 5.000 a USD 100.000 mensuales** mientras persista el incumplimiento, además de sanciones por evento de fuga.

- **Sanciones bajo la Ley 25.326 y observaciones del BCRA** (Com. "A" 7724) por inadecuada protección de datos personales y financieros.
- **Daño reputacional** severo ante una fuga de datos: pérdida de confianza de los 3 bancos clientes y de los tarjetahabientes.

9.6 Próximos pasos recomendados

1. **Acción inmediata (≤48 h):** cambiar las credenciales por defecto en DB-SRV-01 y APP-SRV-02; suspender accesos de terceros sin NDA.
2. **30 días:** implementar MFA en accesos remotos, eliminar cuentas compartidas, deshabilitar Telnet, firmar NDAs de proveedores.
3. **60 días:** ampliar la retención de logs a 12 meses.
4. **90 días:** auditoría de seguimiento para validar la remediación y preparar la recertificación PCI-DSS.

ENTREGABLE 10 — Parte B: Informe Detallado para Gerencia de TI con Hoja de Ruta PCI-DSS

10.1 Resumen de hallazgos por OC

OC	Pruebas realizadas	Conformes	No Conformes	Observaciones	Riesgo residual
OC-1 (Accesos/Trazabilidad)	PT-01, 02, 03, 04, 12	1 (CA-03 parcial)	4	OBS-03, 04, 05	Alto
OC-2 (Red/Configuración)	PT-05, 06, 07, 08	2 (CA-01, CA-02)	2	OBS-01, 02, 06	Crítico
OC-3 (Personal/Terceros)	PT-09, 10, 11	1 (CA-04)	2	OBS-07	Alto

10.2 Detalle técnico de cada observación

OBS-01 (Req. 2.1 — Crítico): DB-SRV-01 autentica con `sa/sa`. Acción técnica: `ALTER LOGIN sa DISABLE`; o renombrar; crear login nominal `CHECK_POLICY=ON`. Validar que ninguna aplicación dependa de "sa".

OBS-02 (Req. 2.1 — Crítico): APP-SRV-02 con `admin/admin`. Acción: `userdel` o renombrar cuenta por defecto; alinear `pwquality.conf` (`minlen=12`, `maxdays=90`); habilitar `fail2ban`.

OBS-03 (Req. 8.2.1 — Alto): Cuenta `operador_cde` compartida. Acción: crear `jperez`, `msosa`, `rgomez`; migrar permisos; `userdel operador_cde`; `sudoers` nominal.

OBS-04 (Req. 8.4.2 — Alto): VPN sin MFA. Acción: integrar VPN-GW-01 con RADIUS/MFA (TOTP); política `mfa = required`; restringir orígenes y geo-bloqueo de salidas Tor.

OBS-05 (Req. 10.7 — Alto): Retención 90 días. Acción: reconfigurar `syslog retention ≥ 365 días`; cold storage; verificación de integridad (Req. 10.5.2); 3 meses online.

OBS-06 (Req. 2.2.1 — Medio): Telnet en SW-CDE-01. Acción: `line vty 0 15 / transport input ssh ; no ip telnet ;` ACL de gestión desde VLAN 300.

OBS-07 (Req. 12.8.3 — Alto): Proveedor sin NDA. Acción: suspender accesos; firmar NDA con cláusula PCI; addendum contractual; registro de proveedores (Req. 12.8.1).

10.3 Hoja de ruta de remediación PCI-DSS

OBS	Acción de remediación	Responsable	Plazo	Prioridad
OBS-01	Deshabilitar/renombrar "sa"; contraseña robusta; enforce policy.	DBA / Gte. TI	≤48 h	Inmediato
OBS-02	Eliminar cuenta "admin"; endurecer política de contraseñas.	Adm. Sistemas	≤48 h	Inmediato
OBS-07	Suspender accesos de terceros sin NDA.	Gte. TI / Legal	≤48 h	Inmediato
OBS-03	Crear cuentas individuales; eliminar cuenta compartida.	Adm. Sistemas	30 días	30d
OBS-04	Implementar MFA en VPN; restringir orígenes.	Adm. Red / Seguridad	30 días	30d
OBS-06	Deshabilitar Telnet; solo SSH; ACL de gestión.	Adm. Red	30 días	30d
OBS-07	Formalizar NDA y addendum contractual; registro de proveedores.	Legal / RRHH	30 días	30d
OBS-05	Ampliar retención de logs a ≥12 meses; cold storage.	Seguridad / Sistemas	60 días	60d
Todas	Auditoría de seguimiento y preparación de recertificación.	Auditoría externa	90 días	90d

10.4 Indicadores de seguimiento sugeridos (KPI/KRI)

Indicador	Meta	Frecuencia
% de sistemas del CDE sin credenciales por defecto	100%	Mensual
% de accesos remotos al CDE con MFA	100%	Mensual
% de cuentas del CDE nominales (sin compartidas)	100%	Mensual
Período de retención de logs (meses)	≥12	Trimestral
Intentos de login fallidos detectados/bloqueados	Tendencia	Semanal
% de proveedores con acceso al CHD con NDA vigente	100%	Trimestral
Cambios en firewall con ticket asociado	100%	Mensual

10.5 Referencias normativas completas

Referencia	Descripción
PCI-DSS v4.0.1, Req. 1.2.1	Diagrama de red actualizado del CDE.
PCI-DSS v4.0.1, Req. 1.3 / 1.3.2	Restricción de tráfico hacia/desde el CDE; denegación por defecto.
PCI-DSS v4.0.1, Req. 1.4	Controles entre redes confiables y no confiables (segmentación).
PCI-DSS v4.0.1, Req. 2.1	Cambio de credenciales/parámetros por defecto del proveedor.
PCI-DSS v4.0.1, Req. 2.2.1 / 2.2.5 / 2.2.7	Configuración segura; deshabilitar servicios inseguros; cifrar acceso administrativo.
PCI-DSS v4.0.1, Req. 7.2	Restricción de acceso por necesidad de saber y función.
PCI-DSS v4.0.1, Req. 8.2.1	ID único por usuario.
PCI-DSS v4.0.1, Req. 8.3.4 / 8.3.6 / 8.3.9	Bloqueo por intentos; longitud/complexidad; rotación de contraseñas.
PCI-DSS v4.0.1, Req. 8.4.2	MFA para todo acceso al CDE.
PCI-DSS v4.0.1, Req. 10.5 / 10.6 / 10.7	Protección, revisión y retención (≥ 12 meses) de logs.
PCI-DSS v4.0.1, Req. 12.8.1 / 12.8.2 / 12.8.3	Gestión de proveedores con acceso al CHD.
ISO/IEC 27002:2022, Control 6.6	Acuerdos de confidencialidad o no divulgación.
ISO/IEC 27002:2022, Control 8.*	Controles tecnológicos (configuración, autenticación, registro).
Ley 25.326 (Argentina)	Protección de Datos Personales; medidas de seguridad de datos.
BCRA Com. "A" 7724	Lineamientos de seguridad de la información y ciberseguridad para entidades del sistema financiero.

Cierre y declaración de responsabilidad

El presente informe se emite con fines académicos (Trabajo Final Integrador). La empresa CardProcess S.A., su personal, los hallazgos, las direcciones IP, los logs y toda la evidencia son **ficticios** y fueron construidos para ilustrar la aplicación metodológica de una auditoría PCI-DSS v4.0.1. Las conclusiones se sustentan en los papeles de trabajo PT-01 a PT-12 y en las observaciones OBS-01 a OBS-07.

Equipo auditor — Holgado, Guzmán & Asociados:

- Holgado Adrián — Líder de Auditoría
- Guzmán Mauro Emir — Auditor Senior
- Chumba Fernando Javier — Especialista Técnico
- Gil Fadda Angel — Auditor
- Sosa Leandro Martín — Auditor

Buenos Aires, 22 de junio de 2026.